greenlight by Medivis

EHR Integration Strategy & Technical Roadmap

SMART on FHIR, Da Vinci Implementation Guides, Multi-Vendor EHR Marketplace Strategy & Security Compliance

6	FHIR R4	Jan 2027	6-12mo
MAJOR EHR VENDORS	UNIVERSAL STANDARD	CMS API MANDATE	FIRST EHR GO-LIVE

Prepared: March 2026

Classification: Confidential — Version 1.0

CONTENTS

Table of Contents

01	Executive Summary & Current State	03
02	SMART on FHIR: The Universal Foundation	04
03	Da Vinci Implementation Guides: CRD, DTR, PAS	05
04	FHIR Resources for Prior Authorization	06
05	EHR Vendor Marketplace Strategy	07
06	Epic Integration: Step-by-Step	08
07	Implementation Phases & Timeline	09
08	Security & Compliance Requirements	10
09	Legal Agreements & Vendor Contracts	11
10	Cost Estimates & Budget	12

SECTION 01

Executive Summary & Current State

GreenLight's core PA workflow and clinical intelligence layer are built. EHR integration is the critical next phase to move from standalone web app to embedded clinical tool.

Current state: GreenLight is a fully functional PA automation platform with a 5-step submission wizard, ACR Appropriateness Criteria matching (11,975 guidelines), pre-submission audit with denial pattern warnings, and a complete dashboard/analytics suite. However, all data entry is manual — no EHR connectivity, no FHIR libraries, no SMART on FHIR implementation. This document lays out the path from standalone to EHR-embedded.

What Exists vs. What Needs to Be Built

Built & Live Today

- ✓ 5-step PA submission wizard with validation
- ✓ Patient, insurance & payer management
- ✓ 11,975 ACR guidelines with risk scoring
- ✓ Pre-submission audit + denial pattern warnings
- ✓ 21 payer clinical policies (5 major payers)
- ✓ Document upload with categorization
- ✓ Denial tracking and appeal filing
- ✓ Full analytics dashboard with export
- ✓ RBM vendor routing (EviCore, Carelon, NIA)
- ✓ Production deployment (Vercel + Neon Postgres)

Not Yet Built

- SMART on FHIR launch + OAuth 2.0 flow
- FHIR R4 data extraction (Patient, Coverage, etc.)
- Da Vinci CRD (CDS Hooks for "is PA required?")
- Da Vinci DTR (auto-populate documentation from EHR)
- Da Vinci PAS (electronic PA submission to payers)
- Epic App Showroom listing
- Oracle Health / Cerner Ignite integration
- PACS/RIS direct integration
- Mirth Connect / integration engine
- SOC 2 Type II certification

The Build-Once, Deploy-Many Advantage

SMART on FHIR is the universal standard. By building a single SMART on FHIR integration layer, GreenLight can launch from inside Epic, Oracle Health, MEDITECH, athenahealth, Veradigm, and eClinicalWorks. The core OAuth + FHIR data extraction is identical across vendors. Vendor-specific work is limited to sandbox testing, certification, and per-site activation. This is a one-time investment that unlocks the entire US hospital market.

~38%	~25%	~16%	450+
EPIC US HOSPITAL MARKET SHARE	ORACLE HEALTH MARKET SHARE	MEDITECH MARKET SHARE	EPIC FHIR R4 API ENDPOINTS

SECTION 02

SMART on FHIR: The Universal Foundation

SMART (Substitutable Medical Applications, Reusable Technologies) on FHIR is the ONC-mandated standard for launching third-party apps inside any compliant EHR. Current version: v2.2.0.

Two Launch Patterns

EHR Launch (Primary)

App launches from within an existing EHR session. The EHR passes an opaque launch context handle; the app inherits the user's session context (current patient, encounter, practitioner). This is the primary integration mode for clinical workflows.

Point-of-order | Context-aware

Standalone Launch

App launches independently from a browser or mobile device, then authenticates against the EHR's FHIR server. Used for administrative workflows, batch processing, and non-clinical users.

Admin workflows | Batch processing

OAuth 2.0 + PKCE Authentication Flow

```
// 1. Discovery
GET {fhir_base}/.well-known/smart-configuration
// Returns: authorization_endpoint, token_endpoint, scopes_supported

// 2. Authorization Request
GET {authorization_endpoint}?
  response_type=code&
  client_id={app_id}&
  redirect_uri={callback}&
  scope=launch patient/Patient.read patient/Coverage.read&
  state={random}&
  code_challenge={pkce_challenge}&
  code_challenge_method=S256

// 3. Token Exchange (after user authorizes)
POST {token_endpoint}
  grant_type=authorization_code&
  code={auth_code}&
  code_verifier={pkce_verifier}

// 4. Returns: access_token, refresh_token, patient (context ID)
```

FHIR Scopes GreenLight Will Request

SCOPE	PURPOSE	PRIORITY
`launch`	Receive EHR launch context (patient, encounter)	Required
`patient/Patient.read`	Auto-fill patient demographics (name, DOB, MRN, gender)	Required
`patient/Coverage.read`	Auto-fill insurance/payer info (plan, member ID, group)	Required
`patient/Condition.read`	Pre-populate ICD-10 diagnosis codes from patient history	Required
`patient/ServiceRequest.read`	Read the procedure/imaging order triggering PA	Required
`patient/DocumentReference.read`	Pull clinical notes for documentation package	Phase 2
`patient/Observation.read`	Extract lab values for clinical justification	Phase 2
`user/Practitioner.read`	Auto-fill ordering/rendering physician details	Phase 3

Key technical decision: Use the `fhirclient` JavaScript library (maintained by SMART Health IT / Boston Children's Hospital) for the OAuth launch flow, and `@smile-cdr/fhirts` for TypeScript FHIR R4 type definitions. These are the standard libraries used by the SMART on FHIR ecosystem.

SECTION 03

Da Vinci Implementation Guides: CRD, DTR, PAS

The HL7 Da Vinci Project defines the three-part electronic Prior Authorization (ePA) framework. These are the standards that CMS-0057-F recommends payers adopt by January 2027.

The integrated workflow: CRD detects PA requirement at point of order → DTR auto-collects documentation from EHR → PAS submits the complete PA request electronically → Payer responds with approval/denial in real-time. This eliminates fax, phone, and portal submissions entirely.

CRD — Coverage Requirements Discovery

Real-time "is PA required?" check at the point of order. Uses CDS Hooks to intercept clinical workflow events inside the EHR.

Mandatory hooks: `appointment-book`, `orders-sign`, `order-dispatch`

Returns: Coverage status, PA requirement (no-auth / auth-needed / satisfied), documentation requirements, payer-specific rules

GreenLight advantage: Our existing ACR criteria engine (11,975 guidelines) and payer policy database power the CRD response. This intelligence is already built — CRD is the delivery mechanism.

CDS Hooks | Real-time | v2.2.1 STU

DTR — Documentation Templates & Rules

Auto-populates documentation requirements by pulling clinical data directly from the EHR. Payers publish FHIR Questionnaire resources with embedded CQL logic.

Workflow: SMART on FHIR app presents Questionnaire → CQL engine auto-fills answers from EHR data → clinician confirms → QuestionnaireResponse generated

Data auto-populated: Clinical notes, lab values, prior imaging results, medication history, diagnosis history, treatment records

SMART launch | CQL engine | v2.2.0 STU

PAS — Prior Authorization Support

Electronic submission of PA requests from EHR to payer via the `Claim/$submit` FHIR operation. Replaces fax, phone, and portal submissions entirely.

Submission bundle: Claim + Patient + Coverage + ServiceRequest + Practitioner + Organization + Condition + Observation + QuestionnaireResponse

Response types:

- **Approved** — with authorization number
- **Denied** — with specific reason code
- **Pended** — with request for additional info

X12 compatibility: Supports conversion to/from X12 278 for backward compatibility with payers not yet on FHIR.

$submit | Real-time | v2.1.0 STU

Why this matters for GreenLight: Today, our PA wizard requires 5 steps of manual data entry. With CRD + DTR + PAS, the workflow becomes: clinician orders an MRI → CRD confirms PA is needed → DTR auto-fills 90%+ of the documentation → PAS submits instantly. The clinician's only action is placing the order. Everything else is automated.

SECTION 04

FHIR Resources for Prior Authorization

The FHIR R4 resources that compose a Prior Authorization Support (PAS) submission bundle, and how each maps to GreenLight's existing data model.

PAS Bundle Structure

FHIR RESOURCE	ROLE IN PA	GREENLIGHT MAPPING	AUTO-FILL SOURCE
Claim (use: preauth)	Primary submission resource; first entry in Bundle	PARequest model	Generated from wizard data
ClaimResponse	Payer response (approval/denial/pend + auth number)	PARequest status + Denial model	From payer API
Patient	Patient demographics	Patient model	EHR context (launch)
Coverage	Insurance/payer information	PatientInsurance model	EHR FHIR API
ServiceRequest	The procedure/imaging order requiring PA	CPT codes + description	EHR order context
Practitioner	Ordering and rendering provider	Ordering/rendering physician fields	EHR user context
Organization	Requesting facility	Organization model	EHR org context
Condition	Diagnosis (ICD-10) supporting medical necessity	ICD-10 codes in wizard Step 2	EHR problem list
Observation	Lab values, vital signs supporting justification	Clinical notes attachment	EHR lab results
DocumentReference	Clinical notes, imaging reports, prior records	Document upload model	EHR document store
QuestionnaireResponse	Completed payer documentation requirements (from DTR)	New — needs implementation	DTR auto-fill + clinician

Data Auto-Fill: What Changes for End Users

Today (Manual Entry)

WIZARD STEP	MANUAL FIELDS
Step 1: Patient	Name, DOB, MRN, gender, insurance
Step 2: Service	Category, CPT, ICD-10, description
Step 3: Insurance	Payer, physician, facility, date
Step 4: Docs	Type clinical notes, upload files
Step 5: Review	Manual review of all fields

Average time per PA: 20–45 minutes

With EHR Integration (Auto-Fill)

WIZARD STEP	AUTO-FILLED FROM
Step 1: Patient	FHIR Patient + Coverage
Step 2: Service	FHIR ServiceRequest + Condition
Step 3: Insurance	FHIR Coverage + Practitioner
Step 4: Docs	DTR + DocumentReference
Step 5: Review	ACR audit (already built)

Target time per PA: **45 seconds** (confirm + submit)

20 min → 45 sec Per-PA processing time reduction with full EHR integration

SECTION 05

EHR Vendor Marketplace Strategy

All major EHR vendors now support FHIR R4 and SMART on FHIR per ONC 21st Century Cures Act requirements. The integration surface is standardized.

EHR VENDOR	MARKET SHARE	MARKETPLACE	FHIR SUPPORT	LISTING COST	KEY REQUIREMENT
Epic	~38%	Showroom / Connection Hub	FHIR R4, 450+ endpoints	~$500/yr	Customer sponsor required
Oracle Health	~25%	App Gallery (Ignite APIs)	FHIR R4 (Ignite)	Free portal	4–8 week validation
MEDITECH	~16%	Alliance Program	FHIR R4, US Core	Not public	Alliance membership
athenahealth	Large ambulatory	Marketplace (800+ apps)	FHIR R4 (ONC HTI-1)	Free	HITRUST self-assess in 90d
Veradigm	Mid-market	App Expo	FHIR R4, SMART v2.0	Free portal	Veradigm certification
eClinicalWorks	Large ambulatory	Developer Portal	FHIR R4, ONC certified	Free	Portal registration

Recommended Sequencing

Priority 1: Epic (Months 1–12)

Largest market share (~38%). Build SMART on FHIR app in Epic sandbox. Find pilot customer (imaging center running Epic). Get listed on Connection Hub. This single integration unlocks the majority of US hospitals.

Timeline: 6–12 months to first production go-live

Dev cost: $200K–$400K including labor

First mover

Priority 2: Oracle Health (Months 9–18)

Second largest share (~25%). SMART on FHIR core transfers directly. Ignite APIs use same FHIR R4 standard. Primarily configuration + vendor-specific testing.

Incremental dev cost: $35K–$70K (read-only), $130K–$300K (bidirectional)

Reuse SMART core

Priority 3: athenahealth (Months 12–18)

Largest ambulatory EHR install base. Free marketplace listing, no interface fees. Excellent for imaging centers and surgical centers that are our primary GTM target.

Requirement: HITRUST self-assessment within 90 days of GA

Ambulatory focus

Priority 4: MEDITECH + Others (Months 15–24)

MEDITECH serves ~16% of hospitals. Alliance Program membership required. Greenfield Workspace sandbox available. Veradigm and eClinicalWorks round out coverage.

Full coverage

Acceleration option: Use **Redox** or **Health Gorilla** as middleware. Single API abstracts EHR differences. Costs ~$1K–5K/month but can cut multi-EHR development time by 50–70%. Consider for Priority 3–4 vendors.

SECTION 06

Epic Integration: Step-by-Step

Epic has ~38% of US hospital market share and is the highest-priority EHR integration target. Here is the complete process from zero to production.

Step 1: Developer Registration

- Register at open.epic.com (free, immediate access)
- Access FHIR documentation, sandboxes, and learning resources
- Review Epic's 450+ FHIR R4 API endpoints across 55 resource types

Timeline: 1–2 days

Step 2: App Registration & Scoping

- Define exact FHIR resources, scopes, and launch context
- Choose EHR Launch (primary) + Standalone Launch (admin)
- Register redirect URIs and configure PKCE

Timeline: 1 week

Step 3: Sandbox Development

- Build SMART on FHIR launch flow against Epic public sandbox
- Implement OAuth 2.0 + PKCE token exchange
- Test FHIR resource reads: Patient, Coverage, Condition, ServiceRequest
- Build auto-fill mapping to GreenLight wizard steps
- Validate against synthetic patient data

Timeline: 2–4 months

Step 4: Customer Sponsorship

- Find at least one Epic customer site willing to sponsor the app
- Customer submits activation request on GreenLight's behalf
- Target: early GreenLight imaging center customer running Epic

Timeline: 1–3 months (critical gate)

Step 5: Epic Technical Review

- Epic engineers review FHIR compliance and SMART implementation
- Functionality, performance, and UX review
- Must demonstrate proper scope handling and error cases

Timeline: 2–8 weeks

Step 6: Security Validation

- Penetration testing and vulnerability assessment
- HIPAA compliance verification
- TLS 1.2+ transport encryption
- OAuth 2.0 with PKCE (mandatory)
- AES-128+ encryption at rest
- SOC 2 Type II report preferred (not always mandatory at this stage)

Timeline: 2–4 weeks

Step 7: Connection Hub Listing

- Execute agreements with Epic Vendor Services
- Annual listing fee: ~$500/year
- Listed in Showroom → visible to all Epic customers

Timeline: 1–2 weeks

Step 8: Per-Site Activation

- Each Epic customer individually activates GreenLight
- Site-specific configuration and data mapping
- User acceptance testing at each site
- Go-live with monitoring and support

Timeline: 2–4 weeks per site

The critical gate is Step 4: Customer Sponsorship. You cannot get an Epic Showroom listing without a live customer. Start building relationships with Epic-running imaging centers now, even before the SMART on FHIR code is complete. The sponsorship process often takes longer than the technical development.

SECTION 07

Implementation Phases & Timeline

A 6-phase roadmap from current state to multi-EHR, fully automated PA submission. Phases overlap to maximize velocity.

Phase 0: Foundation (Weeks 1–4)

- Add FHIR R4 libraries (fhirclient, @smile-cdr/fhirts)
- Create SMART on FHIR launch endpoint (/launch)
- Implement OAuth 2.0 + PKCE flow
- Set up FHIR data extraction service layer
- Begin SOC 2 Type II preparation (parallel)

Milestone: SMART launch working in sandbox

Phase 1: FHIR Data Auto-Fill (Weeks 2–8)

- Map FHIR Patient → Step 1 patient fields
- Map FHIR Coverage → Step 3 insurance fields
- Map FHIR Condition → Step 2 ICD-10 codes
- Map FHIR ServiceRequest → Step 2 CPT/procedure
- Map FHIR Practitioner → Step 3 physician fields

Milestone: 80%+ of wizard auto-filled from EHR

Phase 2: Da Vinci CRD (Weeks 6–12)

- Build CDS Hooks service endpoint
- Implement order-sign, appointment-book hooks
- Connect to existing ACR criteria engine
- Return PA requirement + documentation needs

Milestone: Real-time "is PA required?" in EHR

Phase 3: Da Vinci DTR (Weeks 10–16)

- Build FHIR Questionnaire renderer
- Integrate CQL execution engine for auto-population
- Pull clinical docs via DocumentReference
- Generate QuestionnaireResponse for submission

Milestone: Auto-populated documentation package

Phase 4: Da Vinci PAS (Weeks 14–20)

- Build FHIR Bundle assembly (Claim + supporting resources)
- Implement Claim/$submit operation
- Parse ClaimResponse for approval/denial/pend
- Map responses to GreenLight status tracking
- Add X12 278 fallback via Mirth Connect/Redox

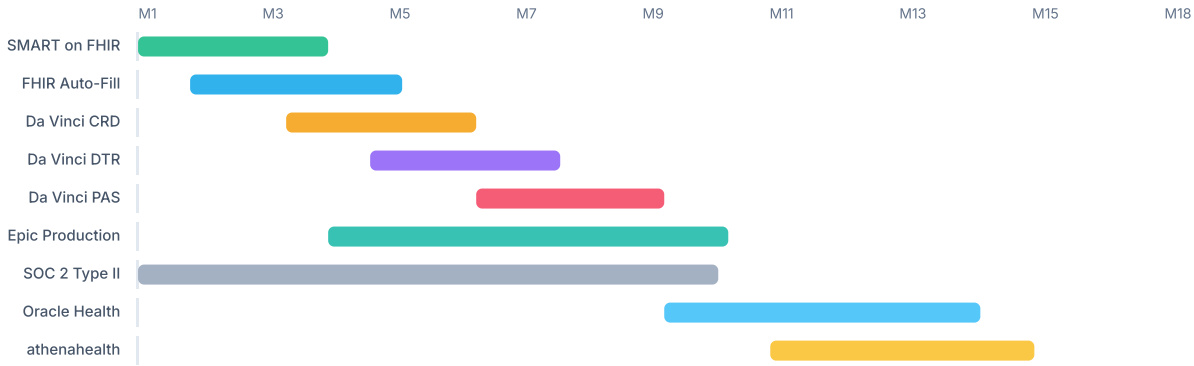
Milestone: End-to-end electronic PA submission

Phase 5: Epic Production (Weeks 8–24)

- Secure customer sponsor for Epic activation
- Complete Epic technical + security review
- Connection Hub listing
- First production go-live at pilot site

Milestone: Live in Epic production environment

Development Gantt Chart



SECTION 08

Security & Compliance Requirements

HIPAA is the floor, SOC 2 is the baseline, HITRUST is the gold standard. Here is the certification pathway and timeline for GreenLight.

Certification Hierarchy

CERTIFICATION	WHAT IT COVERS	COST	TIMELINE	WHEN NEEDED
HIPAA Program	Policies, risk assessment, training, BAA templates	$5-15K	4-6 weeks	Immediate
BAAs	Legal agreements with all entities touching PHI	Legal fees	1-2 weeks	Immediate
SOC 2 Type I	Point-in-time security controls evaluation	$30-50K	3-6 months	Enterprise sales
SOC 2 Type II	Operational effectiveness over 6–12 months	$50-100K	6-12 months	Hospital contracts
HITRUST e1	44 essential controls (fastest HITRUST path)	$80-150K	6-9 months	Large payer/IDN
HITRUST r2	Full risk-based assessment (gold standard)	$150-500K	9-18 months	Enterprise tier
FedRAMP	Federal security authorization (NIST 800-53)	$300K-1M+	12-24 months	Federal contracts

Recommended Compliance Pathway

Phase 1: Immediate (Weeks 1–6)

HIPAA compliance program: Formal policies & procedures documentation, workforce training records, risk assessment, incident response plan. **BAA templates:** Execute BAAs with AWS, Neon (database), Vercel (hosting), and any LLM provider touching PHI.

Gating requirement

Phase 2: SOC 2 Type II (Months 1–12)

Start immediately; runs in parallel with all development work. Engage audit firm (Vanta, Drata, or Secureframe can accelerate). 50–70% control overlap with HITRUST reduces future work. Annual renewal required.

Start now | Runs in parallel

Phase 3: HITRUST e1 (Months 6–15)

Required when enterprise health systems and large payers demand it in procurement. 44 controls (essentials). athenahealth specifically requires HITRUST self-assessment within 90 days of marketplace GA. Current version: CSF v11.7.0.

Enterprise gate

Phase 4: HITRUST r2 / FedRAMP (Year 2+)

HITRUST r2 for comprehensive enterprise assurance. FedRAMP for federal contracts (VA, CMS, DoD, state Medicaid). Consider only when revenue justifies the investment ($150K–1M+). ISO 27001 as foundational layer for international.

Scale-stage

Technical Security Requirements (All EHR Vendors)

TLS 1.2+
TRANSPORT ENCRYPTION (MANDATORY)

AES-256
ENCRYPTION AT REST (RECOMMENDED)

OAuth 2.0
+ PKCE AUTHENTICATION (MANDATORY)

Quarterly
PENETRATION TESTING SCHEDULE

SECTION 09

Legal Agreements & Vendor Contracts

Every entity that touches PHI requires a Business Associate Agreement. Here is the complete legal framework required for EHR integration.

Required Agreements

AGREEMENT TYPE	COUNTERPARTY	WHEN NEEDED	KEY PROVISIONS
Business Associate Agreement (BAA)	Every entity accessing PHI	Before any PHI	Permitted uses/disclosures, safeguards, breach notification (60 days), subcontractor requirements, termination rights
Subprocessor BAAs	AWS, Neon, Vercel, LLM providers	Immediate	Same as above; required for any cloud provider processing PHI on GreenLight's behalf
Epic Vendor Services Agreement	Epic Systems	Epic listing	Connection Hub terms, data handling, revenue sharing (if applicable), SLA requirements
Oracle Health Developer Terms	Oracle Health	Oracle integration	Ignite API terms, per-site activation agreements
athenahealth Partner Agreement	athenahealth	Marketplace GA	Marketplace terms, HITRUST self-assessment commitment within 90 days
Master Services Agreement (MSA)	Each health system customer	Per customer	Service scope, pricing, support obligations, data ownership, indemnification
Service Level Agreement (SLA)	Each customer	Per customer	Uptime (99.95% target), support response times, data handling, disaster recovery
Data Use Agreement (DUA)	Analytics/research partners	Future	De-identified data usage restrictions, re-identification prohibitions
Cyber Liability Insurance	Insurance carrier	Enterprise sales	Many health systems require proof of cyber insurance as procurement prerequisite

BAA Execution Priority

Immediate (Before Any PHI)

- ✓ **AWS** — BAA available through AWS Artifact (self-service)
- ✓ **Neon** (database) — Contact for BAA; ensure HIPAA-eligible tier
- ✓ **Vercel** — Enterprise plan required for BAA and HIPAA compliance
- ✓ **Any LLM provider** — BAA required if PHI enters prompts (AWS Bedrock has BAA; direct Anthropic API requires separate agreement)

Critical infrastructure note: Vercel's standard Hobby/Pro plans do **not** include a BAA. HIPAA-compliant hosting requires either Vercel Enterprise or migrating to a BAA-covered platform (AWS with BAA, Azure with BAA). This must be resolved before any real patient data enters the system. Neon also requires confirming HIPAA eligibility on the current plan tier.

HHS provides model BAA language at hhs.gov/hipaa. Key requirement: BAAs must be executed **before** any PHI is disclosed to the business associate. Review annually and whenever scope of services changes. All BAAs should include breach notification obligations (within 60 days per HIPAA), subcontractor flow-down requirements, and return/destruction of PHI upon termination.

SECTION 10

Cost Estimates & Budget

Total estimated investment for multi-EHR integration: $450K–$950K over 18 months, including development, compliance, and vendor fees.

Development Cost Breakdown

COMPONENT	LOW ESTIMATE	HIGH ESTIMATE	TIMELINE
SMART on FHIR foundation + OAuth	$40K	$80K	4–8 weeks
FHIR data extraction + wizard auto-fill	$30K	$60K	4–6 weeks
Da Vinci CRD (CDS Hooks)	$35K	$70K	4–6 weeks
Da Vinci DTR (Questionnaire + CQL)	$50K	$100K	6–8 weeks
Da Vinci PAS (electronic submission)	$45K	$90K	6–8 weeks
Epic sandbox + certification	$20K	$50K	8–16 weeks
Oracle Health integration	$35K	$70K	8–12 weeks
Additional EHRs (athena, MEDITECH)	$25K	$60K	6–10 weeks
Total Development	**$280K**	**$580K**	**12–18 months**

Compliance & Operational Costs

ITEM	LOW	HIGH	NOTES
HIPAA compliance program	$5K	$15K	Policies, risk assessment, training
SOC 2 Type II (first year)	$50K	$100K	Includes audit firm + remediation + tooling (Vanta/Drata)
HITRUST e1 (when needed)	$80K	$150K	Required by athenahealth within 90 days of GA
Penetration testing (annual)	$10K	$30K	Required by Epic and most health systems
Cyber liability insurance	$5K	$15K	Annual premium; required by enterprise customers
Legal (BAAs, MSAs, vendor agreements)	$15K	$40K	Healthcare attorney review of all agreements
HIPAA-compliant hosting upgrade	$5K	$20K	Vercel Enterprise or AWS migration for BAA coverage
Total Compliance	**$170K**	**$370K**	

$450K – $950K Total 18-Month Investment (Development + Compliance)

Ongoing Annual Costs

ITEM	ANNUAL
Epic Connection Hub listing	~$500
SOC 2 Type II renewal audit	$30–50K
Penetration testing	$10–30K
HIPAA-compliant hosting	$12–36K
Integration middleware (if used)	$12–60K
Total Annual	**$65–177K**

ROI context: At GreenLight's $8/PA pricing with a single hospital system processing 15,000 PAs/month, annual revenue is $1.44M. The full EHR integration investment ($450K–$950K) pays back in 4–8 months from a single large customer. EHR integration is not optional — it is the difference between a demo tool and a production-ready platform that health systems will actually deploy.